

Course Code: CS3433 Name of the Programme: Professional Electives Name of the Course: Web Application Security Semester: VI		
Course credit	No. of hours per week (L + T + P)	Total no. of Teaching hours
2:0:1	30+0+30	60
Course Objectives:		
a) Understand the evolution of software security and identify key web application security threats and mechanisms such as authentication, authorization, and input validation.		
b) Apply secure communication protocols including SSL/TLS and manage secure sessions in web applications.		
c) Perform security testing and plan incident response using industry frameworks like Microsoft SDL, OWASP CLASP, and SAMM.		
d) Implement API security measures and perform vulnerability assessments using industry-standard tools.		

Course outline (Syllabus of the course)

Module 1: Evolution of Software Security and Web Application Security	No. of Hours
	6
The history of Software Security-Recognizing Web Application Security Threats, Web Application Security, Authentication and Authorization, Secure Socket layer, Transport layer Security, Session Management- Input Validation.	
Module 2: Web Application Security: Testing, Incident Response, and Development Lifecycle	No. of Hours
	6
Web Applications Security - Security Testing, Security Incident Response Planning, The Microsoft Security Development Lifecycle (SDL), OWASP Comprehensive Lightweight Application Security Process (CLASP), The Software Assurance Maturity Model (SAMM).	
Module 3: API Security Strategies	No. of Hours
	6
API Security- Session Cookies, Token Based Authentication, Securing Natter APIs: Addressing threats with Security Controls, Rate Limiting for Availability, Encryption, Audit logging, Securing service-	

to-service APIs: API Keys , OAuth2, Securing Microservice APIs: Service Mesh, Locking Down Network Connections, Securing Incoming Requests.

Module 4: Vulnerability Assessment and Penetration Testing (VAPT): Tools and Techniques	No. of Hours
	6

Vulnerability Assessment Lifecycle, Vulnerability Assessment Tools: Cloud-based vulnerability scanners, Host-based vulnerability scanners, Network-based vulnerability scanners, Database based vulnerability scanners, Types of Penetration Tests: External Testing, Web Application Testing, Internal Penetration Testing, SSID or Wireless Testing, Mobile Application Testing.

Module 5: Web Application Security: Common Vulnerabilities and Tools	No. of Hours
	6

Social Engineering, Injection, Cross-Site Scripting(XSS), Broken Authentication and Session Management, Cross-Site Request Forgery, Security Misconfiguration, Insecure Cryptographic Storage, Failure to Restrict URL Access, Tools: Comodo, OpenVAS, Nexpose, Nikto, Burp Suite, etc.

Course Outcomes: After completing the course, the students will be able to: -	
a)	Identify the various types of threats and mitigation measures of web applications.
b)	Examine the process of secure development and deployment of web applications
c)	Analyze the various functionalities to build Secure APIs
d)	Apply ethical hacking techniques and tools to perform vulnerability assessments and penetration testing for strengthening cybersecurity.

Textbook Books	
1	Andrew Hoffman, Web Application Security: Exploitation and Countermeasures for Modern Web Applications, First Edition, 2020, O'Reilly Media, Inc, ISBN: 9781492053118.
2	Bryan Sullivan, Vincent Liu, Web Application Security: A Beginners Guide, 2012, The McGraw-Hill Companies, ISBN: 978-0071776165.
3	Neil Madden, API Security in Action, 2020, Manning Publications Co., NY, USA, ISBN 9781617296024.

Reference Books	
1.	Michael Cross, Developer's Guide to Web Application Security, 2007, Syngress Publishing, Inc, 978-ISBN: 1597490610.
2.	Ravi Das and Greg Johnson, Testing and Securing Web Applications, 2021, Taylor & Francis Group, LLC, ISBN: 978-0367333751.
3.	Prabath Siriwardena, Advanced API Security, Apress Media LLC, USA. Malcom McDonald, Web Security for Developers, 2020, No Starch Press, Inc, ISBN 978-1-4842-2050-4.

Lesson Plan (Template – 2)

Name of the Programme:	BTech	
Title of the Course:	Web Application Security	
Course Code	CS3433	
Semester:	VI	
Names of the Course Instructor(s)	Dr. Manish Kumar	
Course credit	No. of hours per week: (L + T + P)	Total No. of Teaching Hours
3	2+0+2	60

Session	Module No.	Topic	Pedagogy /activities	Pre-reading/reference
1.	1	History of Software Security	Lecture	Hoffman Ch.1
2.		Web Application Security & Threat Landscape	Lecture	Hoffman Ch.1
3.		Authentication & Authorization Weaknesses	Hands-on Lab	Burp Suite Academy
4.				
5.		Authentication, Authorization Models	Lecture	Hoffman Ch.3
6.		SSL, TLS and Secure Communication	Lecture	Sullivan Ch.4
7.		Session Handling & Account Recovery Flaws	Hands-on Lab	Burp Suite Academy
8.				
9.		Session Management	Lecture	Hoffman Ch.5
10.		Input Validation Techniques	Lecture	OWASP Cheat Sheets
11.		Input Validation & Client-side Attacks	Hands-on Lab	Burp Suite Academy
12.				
13.	2	Web Application Security Testing	Lecture	Hoffman Ch.6

14.		Security Testing Tools Overview	Lecture	OWASP ZAP Docs
15.		Injection & Error Handling Issues	Hands-on Lab	Burp Suite Academy
16.				
17.		Security Incident Response Planning	Lecture	NIST IR Guide
18.		Incident Detection & Containment	Lecture	NIST Framework
19.		Secure Coding & Deployment Gaps	Hands-on Lab/Activity-based	Burp Suite Academy
20.				
21.		Microsoft SDL	Lecture	Microsoft SDL
22.		OWASP CLASP & SAMM	Lecture	OWASP Docs
23.		High-level logic vulnerability-Business logic vulnerability	Hands-on Lab/Activity-based	Burp Suite Academy
24.				
25.	3	Introduction to API Security	Lecture	Madden Ch.1
26.		Session Cookies & Token Authentication	Lecture	Madden Ch.2
27.		JWT authentication bypass via weak signing key	Hands-on Lab	Burp Suite Academy
28.				
29.		Securing REST APIs	Lecture	OWASP API Top 10
30.		Rate Limiting, Encryption, Audit Logs	Lecture	Madden Ch.4
31.		OAuth account hijacking via redirect uri	Hands-on Lab	Burp Suite Academy
32.				
33.		OAuth2 & API Keys	Lecture	OAuth2 RFC
34.		Securing Microservice APIs	Lecture	Service Mesh Docs
35.		1. Basic SSRF against the local server	Hands-on Lab	Burp Suite Academy
36.				

		2. Exploiting a mass assignment vulnerability		
37.	4	Vulnerability Assessment Lifecycle	Lecture	Cross Ch.3
38.		Vulnerability Scanners Overview	Lecture	OpenVAS Docs
39.		SQL injection UNION attack, retrieving data from other tables	Hands-on Lab	Burp Suite Academy
40.				
41.		Types of Penetration Testing	Lecture	OWASP Testing Guide
42.		Web Application Penetration Testing	Lecture	Hoffman Ch.7
43.		1. OS command injection, simple case 2. File path traversal, simple case	Hands-on Lab	Burp Suite Academy
44.				
45.		Mobile & Wireless Penetration Testing	Lecture	OWASP Mobile
46.		Reporting & Risk Analysis	Lecture	PTES Docs
47.		Exploiting cross-site scripting to steal cookies	Hands-on Lab	Burp Suite Academy
48.				
49.	5	Social Engineering Attacks	Lecture	Mitnick Concepts
50.		Injection Attacks (SQLi)	Lecture	OWASP Top 10
51.		Stored XSS into HTML context	Hands-on Lab	Burp Suite Academy
52.				

		with nothing encoded		
53.		Cross-Site Scripting (XSS)	Lecture	Hoffman Ch.8
54.		CSRF & Broken Authentication	Lecture	OWASP Docs
55.		1. CSRF vulnerability with no defenses		
56.		2. CORS vulnerability with basic origin reflection	Hands-on Lab	Burp Suite Academy
57.		Security Misconfiguration & Crypto Issues	Lecture	OWASP
58.		Web Security Tools Overview	Lecture	Tool Manuals
59.		Web shell upload via content-type restriction bypass	Hands-on Lab	Burp Suite Academy
60.				

Assessment and Evaluation

Continuous Internal Evaluation (CIE)	
Components of CIE	Weightage of Each Component
Graded Component 1 (Quiz)-CIE-1	10 %
Practical Component (Lab-Based Test)-CIE-1	10 %
Mid Sem Examination (Theory)-CIE-2	25 %
Practical Component (Lab-Based Test)-CIE-3	15 %
Assignment + Demo – CIE -3	10 %

Semester End Exams (SEE)	
Mode of Exam	Theory
Weightage of Exam	30 %

Course Outcomes- Programme Outcomes Matrix

Course Outcome \ Program Outcome		PO1	PO2	PO3	PO4	PO5	PO6	PO7	PO8	PO9	PO10	PO11	PO12
CO1	Identify the various types of threats and mitigation measures of web applications.	3	3	-	2	-	-	-	1	-	2	-	-
CO2	Examine the process of secure development and deployment of web applications	3	2	2	3	-	-	1	2	-	2	-	-
CO3	Analyze the various functionalities to build Secure APIs	3	3	2	3	-	-	1	2	-	2	-	-
CO4	Apply ethical hacking techniques and tools to perform vulnerability assessments and penetration testing for strengthening cybersecurity.	3	3	2	2	-	1	2	2	-	3	-	-

Evaluation of Components

Assessment Component	Type of Component	Rubrics for Assessment
1.	Quiz	Quiz will be conducted for 10 marks. It will consist of scenario-based multiple-choice questions related to web application security threats, secure coding practices, and API security concepts. Each correct answer carries one mark. No negative marking for wrong answers.
2.	Lab Test	Lab-based assessment will be conducted for 10 marks. Students will be required to identify and exploit a given vulnerability and apply suitable mitigation measures. Marks will be awarded based on correct approach, execution, and validation of results.

3.	Mid Sem	The Mid-Semester Examination will be conducted for 25 marks. Questions will be case-based and analytical, covering web application security fundamentals, secure development lifecycle, and testing methodologies. Evaluation will be done according to the Scheme of Evaluation prepared by the team of course faculty.
4.	Practical Component (Lab Test)	Lab-based practical test will be conducted for 15 marks. Students will perform multi-step security assessment tasks such as vulnerability scanning, exploitation, and analysis. Marks will be awarded based on methodology, accuracy, and interpretation of results.
5.	Assignment + Demo	Assignment and demonstration will be evaluated for 10 marks. Students will submit a security analysis report and demonstrate a secure application/API or vulnerability mitigation. Assessment will be based on technical correctness, clarity of explanation, and demonstration of ethical hacking practices.
6.	SEE	The test will be conducted out of 30 marks and will be evaluated according to the Scheme of Evaluation prepared by a team of course faculty.

Rubrics

Assessment Component 1

1.1 Quiz (10 Marks)

- **Type:** Objective-based written quiz.
- **Rubrics:**
 - Each correct answer = **1 mark**
 - **No negative marking** for wrong answers.
 - Quiz covers basic concepts from recent lectures or labs.

1.2 Lab Test (10 Marks)

- **Type:** Hands-on coding evaluation based on recent lab topics.
- **Rubrics:**

Criteria	Excellent (8–10)	Good (5–7)	Satisfactory (3–4)	Poor (0–2)
Vulnerability Identification	Correctly identifies vulnerability and root cause	Identifies vulnerability with partial understanding	Identifies issue without clarity	Unable to identify vulnerability

Exploitation / Execution	Successfully performs exploitation using correct methodology	Executes with minor mistakes	Partial execution	No execution
Mitigation & Validation	Applies correct fix and validates results	Fix applied but not fully validated	Fix attempted incorrectly	No mitigation attempted

Assessment Component 2

Mid Semester Exam (25 Marks)

- **Type:** Descriptive and problem-solving written test.
- **Rubrics:** Evaluation based on **Scheme of Evaluation** created by the course instructors.

Assessment Component 3

3.1 Lab Test (15 Marks)

Criteria	Excellent (12–15)	Good (8–11)	Satisfactory (4–7)	Poor (0–3)
Methodology & Approach	Follows systematic VAPT methodology	Mostly systematic with minor gaps	Unstructured approach	No clear approach
Tool Usage	Uses appropriate tools effectively	Uses tools with limited efficiency	Misuse of tools	Unable to use tools
Analysis & Interpretation	Accurately analyzes and interprets results	Reasonable interpretation	Partial interpretation	No interpretation

3.2 Rubrics for Assignment + Demo – CIE-3 (10 Marks)

Criteria	Excellent (8–10)	Good (5–7)	Satisfactory (3–4)	Poor (0–2)
Technical Content	Accurate, comprehensive security analysis	Mostly correct with minor gaps	Limited technical depth	Incorrect or insufficient
Demonstration & Explanation	Clear, confident demo with strong justification	Clear demo with minor gaps	Weak explanation	Unable to explain

Ethical & Best Practices	Clearly demonstrates ethical hacking practices	Mostly ethical practices	Limited ethical awareness	Ethical concerns observed
--------------------------	--	--------------------------	---------------------------	---------------------------